



# Enterprise Billing Portal: 2FA & Infrastructure Guide

Multi-Factor Authentication (TOTP), Web Admin Control Center & Production Docker Deployment

Portal URL: <https://billing.chettiyarkada.in> | Admin URL: <https://billing.chettiyarkada.in/gate/admin>

## 1. System Overview & Perimeter Security Architecture

To protect Chettiyar Kada's financial, invoicing, and POS infrastructure, an enterprise **Two-Factor Authentication (2FA) Reverse-Proxy Access Gate** is deployed for <https://billing.chettiyarkada.in>. Unauthenticated browsers attempting to access billing or administrative routes are intercepted at the Nginx edge and challenged for staff credentials and a synchronized **Google Authenticator (RFC 6238 TOTP)** 6-digit passcode before receiving access to the internal ERPNext application.

**Customer Exemption:** The product catalogue (</frontend/catalogueviewer>), catalogue media (</files/>), and frontend styling assets are kept completely public and excluded from 2FA so retail shoppers can browse store offers without barriers.

## 2. Provisioned Administrator Credentials

| Parameter             | Configuration Details                                                                                                                               |
|-----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Portal Login          | <a href="https://billing.chettiyarkada.in">https://billing.chettiyarkada.in</a> → /gate/login                                                       |
| Admin Control Center  | <a href="https://billing.chettiyarkada.in/gate/admin">https://billing.chettiyarkada.in/gate/admin</a> (Requires Admin role)                         |
| Public Catalogue      | <a href="https://billing.chettiyarkada.in/frontend/catalogueviewer">https://billing.chettiyarkada.in/frontend/catalogueviewer</a> (No 2FA required) |
| Initial Administrator | Username: <b>admin</b>   Role: <b>ADMIN</b>                                                                                                         |
| Initial Password      | <b>ChettiyarAdmin2026!</b>                                                                                                                          |
| TOTP Secret Key       | WG56VR7SCCF3AI3TQUB2050KCC06CXGWW (RFC 6238 Base32)                                                                                                 |
| Session Duration      | 12 Hours • Signed HMAC-SHA256 Token (HttpOnly; Secure; SameSite=Lax)                                                                                |
| Brute-Force Guard     | Automatic IP lockout after 5 failed attempts for 15 minutes                                                                                         |

## 3. Google Authenticator Smartphone Pairing



### Scan with Google Authenticator:

1. Open the **Google Authenticator** app on your iOS or Android mobile phone.
2. Tap the + button (bottom-right) and select **Scan a QR code**.
3. Point your camera at the QR code displayed to the left to enroll.
4. **Manual Entry Key:** Enter account **Chettiyar Kada:admin**, Key: WG56VR7SCCF3AI3TQUB2050KCC06CXGWW, Type: **Time-based**.
5. The authenticator will generate a rolling 6-digit passcode refreshed every 30 seconds.

**CONFIDENTIALITY NOTICE:** Anyone with access to this QR code and password can authenticate into the billing portal. Keep this document confidential and change default passwords immediately after initial setup.

## 4. Web Admin Control Center (/gate/admin)

A dedicated, browser-based management dashboard is hosted at <https://billing.chettiyarkada.in/gate/admin>. It provides full administrative control over both the **reverse-proxy routing tier (Nginx)** and **staff authentication & 2FA credentials** without requiring terminal or SSH access. Restricted exclusively to accounts with the **Administrator** role.

| Feature Area                | Capabilities & Operations                                                                                                                                                                                                                                                                                                                                         | Safety / Safeguards                                                                                  |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------|
| ■ Nginx Site Management     | <ul style="list-style-type: none"> <li>List all configuration files in /etc/nginx/sites-available</li> <li>Real-time Nginx daemon PID and running state indicator</li> <li>One-click toggle switch to Enable or Disable sites</li> <li>Parsed display of domains, listen ports, SSL, and 2FA status</li> </ul>                                                    | Symlinks in sites-enabled are tested automatically with <code>nginx -t</code> before applying.       |
| —■ In-Browser Config Editor | <ul style="list-style-type: none"> <li>Full code editor with syntax indentation and monospace font</li> <li>Predefined site templates (2FA Reverse Proxy, Standard Proxy, Static Site)</li> <li>One-click <b>Test Syntax</b> button runs <code>nginx -t</code></li> <li><b>Save &amp; Reload Nginx</b> applies changes without dropping active clients</li> </ul> | <b>Automatic Rollback:</b> If syntax validation fails, changes are reverted immediately from backup. |
| ■ Staff & 2FA Management    | <ul style="list-style-type: none"> <li>Add new staff with role assignment (<b>Staff</b> vs <b>Administrator</b>)</li> <li>Instant on-screen Google Authenticator QR code with copyable secret</li> <li>Re-pair / Reset 2FA with new QR generation on mobile changes</li> <li>Update staff passwords with salted <code>scrypt</code> hashing</li> </ul>            | Safeguards prevent administrators from deleting their own account or removing the last admin.        |
| ■■■ Brute-Force Monitoring  | <ul style="list-style-type: none"> <li>Live monitor of rate-limited and locked-out client IPs</li> <li>Displays failed attempt counts and remaining lockout seconds</li> <li>One-click <b>Unblock IP</b> button to immediately restore access</li> </ul>                                                                                                          | Configured with 5 max failed attempts and a 15-minute sliding lockout window.                        |

## 5. Role-Based Access Control & Daily Staff Login Workflow

The access gate enforces strict Role-Based Access Control (RBAC):

- **Staff Role:** Authorized to authenticate into ERPNext / Frappe billing and POS interfaces. Access to /gate/admin is blocked with a 403 Forbidden page.
- **Administrator Role:** Full access to both the Billing Portal and the Gate & Nginx Control Center.

### Staff Login Workflow:

1. Open <https://billing.chettiyarkada.in> in any web browser (redirects automatically to /gate/login).
2. Enter registered staff **Username** and **Password**.
3. Open **Google Authenticator**, read the 6-digit rolling code, and submit the form.
4. Upon verification, an encrypted HMAC cookie is issued and the user is redirected to the billing dashboard.
5. To log out, navigate to <https://billing.chettiyarkada.in/gate/logout> to revoke session cookies.

## 6. Production Docker Containerization & Deployment

For enterprise production deployment, **Billing Gate** is packaged as a high-security, lightweight **Docker container**. This containerizes the Node.js authentication service while seamlessly integrating with the host's existing Nginx reverse proxy.

| Architectural Component | Production Specification & Implementation Details                                                                                                                         |
|-------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Base Container Image    | Node.js 20 LTS on Alpine Linux (node:20-alpine). Total image size is ~51 MB.                                                                                              |
| Security Hardening      | Runs as an unprivileged non-root user (node, UID 1000). The entrypoint script verifies data permissions and drops privileges using su-exec.                               |
| Network Isolation       | Port binding: 127.0.0.1:3100:3100. The service is bound strictly to the local loopback interface on the host, ensuring it is only accessible via the Nginx reverse proxy. |
| Data Persistence        | Host volume mount: /var/lib/billing-gate:/var/lib/billing-gate. Stores users.json and HMAC secret.key persistently across restarts.                                       |
| Nginx Management Mounts | Mounted volumes: /etc/nginx:/etc/nginx, /etc/letsencrypt:/etc/letsencrypt:ro, and shared host PID (pid: host) allowing in-container Nginx syntax checks and reloads.      |
| Container Health Check  | Native Node.js fetch healthcheck polling http://127.0.0.1:3100/gate/health every 30s.                                                                                     |
| Logging & Rotation      | JSON-file logging driver with automatic log rotation (max-size: 10m, max-file: 3).                                                                                        |

## 7. Docker Operations & Systemd Switchover

### A. Quick Start via Docker Compose:

```
cd /var/www/billing-gate && docker compose up -d --build
```

### B. Zero-Disruption Switchover from Bare-Metal to Docker:

Because both the host Node.js service and the Docker container publish to 127.0.0.1:3100, switching from bare-metal to Docker requires **zero changes** to Nginx configuration files:

1. Stop bare-metal service: `sudo systemctl stop billing-gate.service && sudo systemctl disable billing-gate.service`
2. Launch Docker Compose: `docker compose up -d`
3. Enable Systemd Docker unit: `sudo cp systemd/billing-gate-docker.service /etc/systemd/system/ && sudo systemctl daemon-reload && sudo systemctl enable billing-gate-docker.service`

### C. Container Management CLI Helper (./gate-cli.sh):

To manage accounts inside the running Docker container with interactive terminal QR codes:

- Add staff user: `./gate-cli.sh add-user <username> <password> [admin|staff]`
- List all users: `./gate-cli.sh list-users`
- Reset TOTP / Re-pair: `./gate-cli.sh reset-totp <username>`
- Update password: `./gate-cli.sh set-password <username> <newpass>`
- Delete account: `./gate-cli.sh delete-user <username>`

## 8. Complete Command & Infrastructure Reference

Reference sheet for system administrators managing Chettiyar Kada's 2FA access gate across bare-metal and Docker environments:

| Operational Task   | Docker Compose Mode                                          | Bare-Metal Systemd Mode                             |
|--------------------|--------------------------------------------------------------|-----------------------------------------------------|
| Start Service      | <code>docker compose up -d</code>                            | <code>systemctl start billing-gate</code>           |
| Stop Service       | <code>docker compose down</code>                             | <code>systemctl stop billing-gate</code>            |
| Service Status     | <code>docker compose ps</code>                               | <code>systemctl status billing-gate</code>          |
| Live Logs          | <code>docker compose logs -f</code>                          | <code>journalctl -u billing-gate -f</code>          |
| Health Probe       | <code>curl http://127.0.0.1:3100/gate/health</code>          | <code>curl http://127.0.0.1:3100/gate/health</code> |
| Add Admin User     | <code>./gate-cli.sh add-user u p admin</code>                | <code>node cli.js add-user u p admin</code>         |
| Add Staff User     | <code>./gate-cli.sh add-user u p staff</code>                | <code>node cli.js add-user u p staff</code>         |
| List Users & Roles | <code>./gate-cli.sh list-users</code>                        | <code>node cli.js list-users</code>                 |
| Reset TOTP QR      | <code>./gate-cli.sh reset-totp &lt;user&gt;</code>           | <code>node cli.js reset-totp &lt;user&gt;</code>    |
| Update Password    | <code>./gate-cli.sh set-password u p</code>                  | <code>node cli.js set-password u p</code>           |
| Nginx Syntax Test  | Via <code>/gate/admin</code> or <code>nginx -t</code>        | <code>sudo nginx -t</code>                          |
| Nginx Reload       | Via <code>/gate/admin</code> or <code>nginx -s reload</code> | <code>sudo systemctl reload nginx</code>            |

## 9. Key File Paths & Repository Architecture Map

| Path / Location                                                  | Purpose / Description                                                                                 |
|------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| <code>/var/www/billing-gate/Dockerfile</code>                    | Production multi-stage Alpine Linux container build definition                                        |
| <code>/var/www/billing-gate/docker-compose.yml</code>            | Container orchestration specification, volume mappings, and loopback port bindings                    |
| <code>/var/www/billing-gate/views/admin.html</code>              | Interactive Web Admin Control Center (Nginx & user management)                                        |
| <code>/var/www/billing-gate/lib/nginx.js</code>                  | Backend engine for Nginx directive parsing, syntax testing ( <code>nginx -t</code> ), and safe reload |
| <code>/var/www/billing-gate/gate-cli.sh</code>                   | Interactive CLI wrapper script executing commands inside the Docker container                         |
| <code>/var/lib/billing-gate/users.json</code>                    | Persistent atomic JSON database storing staff credentials, roles, and TOTP secrets                    |
| <code>/var/lib/billing-gate/secret.key</code>                    | High-entropy 256-bit cryptographically random signing key for session HMAC cookies                    |
| <code>/etc/nginx/sites-available/billing.chettiyarkada.in</code> | Production Nginx reverse-proxy configuration with 2FA subrequest verification                         |